Plan de certificación

InvierteYa · Equipo D · Sesión 2 — Casos de prueba automatizados: `tests/test_flujo.py` (CP-01 a CP-15) y `tests/test_ia.py` (CP-16 a CP-21) · Diagramas de referencia: `docs/DIAGRAMAS.md` · Mensajería: `docs/API_ISO8583.md`

> **Simulado:** la pasarela, el adquirente, el suiche, el emisor, el banco fiduciario, la casa de bolsa y la CVV son servicios simulados del prototipo. Los casos de prueba se ejecutan hoy contra esos simuladores; en la certificación real se repiten en el **sandbox de la pasarela aliada** y ante cada actor. Las normas citadas se tomaron del documento de la Sesión 1 (sección 8) y deben confirmarse en su versión vigente.

1. Objetivo y alcance

Definir **qué certificaciones y autorizaciones necesita InvierteYa para operar**, **quién participa** en cada una y **con qué casos de prueba se demuestra** que el flujo de aportes (autorización → captura → reverso → conciliación) y el perfil de riesgo con IA funcionan como se diseñaron.

El plan se divide en dos fases, porque en la fase 1 InvierteYa **no es la pasarela**: se apoya en una pasarela ya certificada y busca su independencia más adelante.

	Fase 1 — Operar con una pasarela certificada	Fase 2 — Independencia
Quién arma los mensajes ISO 8583	La pasarela aliada	InvierteYa, vía su adquirente
¿El PAN llega a InvierteYa?	**No** (tokenización en la pasarela)	Sí, a una bóveda de tokens propia
Alcance PCI-DSS 4.0	Mínimo: **SAQ A**	Completo (SAQ D o ROC con QSA, según volumen)
Homologación con el suiche	No aplica (la hace la pasarela)	Sí
Objetivo	Salir al mercado rápido y con bajo costo	Bajar comisiones y controlar la experiencia de pago

2. Certificaciones y autorizaciones requeridas

2.1 Fase 1 (lanzamiento)

#	Certificación / autorización	Ante quién	Qué se demuestra	Evidencia que entregamos
F1-1	**Certificación de la integración con la pasarela**	Pasarela aliada (su equipo de certificación, en su sandbox)	Que InvierteYa consume bien su API: tokenización, autorización, captura, reverso, idempotencia, manejo de rechazos y timeouts, lectura del archivo de liquidación	Ejecución de CP-01 a CP-15 en el sandbox; registro de solicitudes y respuestas; `docs/openapi.yaml`
F1-2	**PCI-DSS 4.0 — SAQ A** (autoevaluación)	Banco adquirente / pasarela (reciben el SAQ y la Atestación de Cumplimiento, AOC)	Que InvierteYa **no almacena, procesa ni transmite** datos de tarjeta: la captura del PAN ocurre en el formulario o iframe de la pasarela	SAQ A firmado; AOC vigente **de la pasarela**; CP-04 (el PAN nunca llega); diagrama C4 nivel 2
F1-3	**Autorización como fintech**	SUDEBAN (Res. N° 001.21, servicios de tecnología financiera; Res. 137.09, banca electrónica)	Gobierno corporativo, seguridad de la información, gestión de riesgos tecnológicos y canales electrónicos	Expediente de la fintech; políticas de seguridad; este plan y sus resultados
F1-4	**Uso de nube pública**	SUDEBAN (circular sobre servicios de computación en la nube) y SUNAVAL	Autorización previa y declaración de la ubicación física de los servidores; plan para réplica local si se exige	Arquitectura (Sesión 1, sección 6.3); contrato con el proveedor de nube
F1-5	**Contrato marco del fideicomiso y convenio de alianza**	Banco fiduciario (supervisado por SUDEBAN)	Política de inversión, 3 portafolios, límites, reparto de comisiones; "InvierteYa propone, el fiduciario aprueba"	Contrato firmado; CP-13 (batch aprobado por el fiduciario); CP-11 (sin adhesión no hay aporte)
F1-6	**Operación de inversión vía app con intermediario autorizado**	SUNAVAL (Ley de Mercado de Valores y lineamientos para operaciones de inversión vía aplicaciones de las casas de bolsa)	Que las compras de títulos las ejecuta una casa de bolsa autorizada por instrucción del fiduciario	Convenio con la casa de bolsa; flujo del diagrama 2
F1-7	**Prevención de LC/FT (AML/KYC)**	SUDEBAN / banco fiduciario (LOCDOFT y normas SIAR LC/FT/FPADM)	Verificación de identidad antes de operar, resultado del KYC compartido con el banco, monitoreo de operaciones inusuales	Flujo de registro → KYC → adhesión; manual de prevención
F1-8	**Validación del modelo de IA**	Comité interno de riesgo + banco fiduciario (idoneidad del perfil)	Que el perfil de riesgo cumple metas, respeta las reglas de seguridad y tiene supervisión humana	CP-16 a CP-21; `docs/ia/MODELO.md`; `docs/ia/metricas.json`

2.2 Fase 2 (independencia)

Disparador: pasar a la fase 2 cuando el costo anual de las comisiones de la pasarela (supuesto: 3% por aporte) **supere el costo anual de certificarse y operar** la conexión directa (auditorías, infraestructura PCI, homologación).

#	Certificación	Ante quién	Qué cambia respecto a la fase 1
F2-1	**Homologación con el suiche**	Suiche nacional y banco adquirente	InvierteYa (o su procesador) arma y recibe los mensajes ISO 8583 (0100/0110, 0220/0230, 0400/0410, 0420/0421, 0500); se certifican campos, códigos de respuesta y tiempos
F2-2	**Afiliación directa como comercio**	Banco adquirente	Contrato de afiliación, límites, liquidación directa a la cuenta del fideicomiso
F2-3	**PCI-DSS 4.0 completo**	QSA (auditor certificado) o SAQ D, según el nivel de volumen definido por las marcas	Bóveda de tokens propia con gestión de llaves (KMS/HSM), segmentación de la zona PCI, escaneos trimestrales por un ASV y pruebas de penetración
F2-4	**Segundo banco fiduciario**	SUDEBAN / nuevo fiduciario	Procedimiento de sustitución o diversificación del fiduciario para reducir la dependencia

3. Actores involucrados

Actor	Rol en la certificación	Responsable por InvierteYa
InvierteYa (equipo técnico y de cumplimiento)	Ejecuta los casos de prueba, prepara la evidencia, firma el SAQ A y los expedientes	Líder técnico + oficial de cumplimiento
Pasarela aliada	Provee el sandbox, certifica la integración y entrega su AOC PCI-DSS	Líder técnico
Banco adquirente	Recibe el SAQ A/AOC; en la fase 2, afilia a InvierteYa y acompaña la homologación	Oficial de cumplimiento
Suiche nacional	En la fase 2, homologa los mensajes ISO 8583	Líder técnico
Banco emisor	Aprueba o rechaza los pagos (simulado en el sandbox con códigos 00, 05, 51, 59)	—
Banco fiduciario	Firma el contrato marco, aprueba los batch de órdenes, recibe el KYC	Gerente de alianzas
Casa de bolsa / CVV	Ejecutan y custodian las compras de títulos que instruye el fiduciario	Gerente de alianzas
SUDEBAN	Autoriza la operación fintech, la nube y supervisa la prevención de LC/FT	Oficial de cumplimiento
SUNAVAL	Supervisa la operación de inversión vía app a través de intermediarios autorizados	Oficial de cumplimiento
QSA / ASV (fase 2)	Auditan PCI-DSS completo y escanean vulnerabilidades	Líder de seguridad

4. Casos de prueba

Los 21 casos están **automatizados con pytest** y se corrieron sobre el prototipo con los servicios simulados.

Resultado de la ejecución: 21 de 21 pasan (pytest 9.2, Python 3.13, Windows, 8-nov-2026; tiempo total 16,6 s). Comando: `python -m pytest -v`.

4.1 Flujo transaccional (certificación de la integración con la pasarela, F1-1 y F1-2)

ID	Caso	Escenario forzado	Resultado esperado	Requisito que cubre	Resultado
CP-01	Aporte aprobado	`APROBADA`	Estados PENDIENTE → AUTORIZADO → CAPTURADO → ASIGNADO; 16 unidades ($20 / $1,25); mensajes 0100/0110 y 0220/0230; lección del tutor al asignar unidades	Autorización y captura (diagramas 1 y 2)	✅ Pasa
CP-02	Rechazo por saldo insuficiente	Código `51`	Estado RECHAZADO; mensaje "saldo insuficiente"; el tutor **no** aparece	Manejo de rechazos	✅ Pasa
CP-03	Rechazo por sospecha de fraude	Código `59`	Estado RECHAZADO; el mensaje **no** revela que fue por fraude	Manejo de rechazos; seguridad	✅ Pasa
CP-04	El PAN nunca llega a InvierteYa	`APROBADA` con tarjeta de prueba	El número completo no aparece en ninguna respuesta; el campo 2 va enmascarado (`4111********1111`)	**PCI-DSS SAQ A** (F1-2)	✅ Pasa
CP-05	Timeout de autorización	`TIMEOUT` (30 s)	Reverso automático con mensaje 0400 y campo 90 (datos de la transacción original)	Reverso (diagrama 3)	✅ Pasa
CP-06	Falla de captura	`APROBADA` + `FALLA_CAPTURA`	Se reversa la autorización; no se asignan unidades	Reverso (diagrama 3)	✅ Pasa
CP-07	Reverso sin respuesta	`TIMEOUT` + `REVERSO_SIN_RESPUESTA`	Aviso 0420 + 3 repeticiones 0421; el aporte queda REVERSO_PENDIENTE y pasa a la cola de excepciones	Reverso; ISO 8583	✅ Pasa
CP-08	Idempotencia	Dos solicitudes con la misma `Idempotency-Key`	La segunda devuelve el mismo aporte marcado como duplicado; una sola autorización en la pasarela	No cobrar dos veces	✅ Pasa
CP-09	Captura sin autorización	Captura de un id inexistente	La pasarela responde `NOT_CAPTURABLE`	Integridad del flujo	✅ Pasa
CP-10	Monto mínimo	Aporte de $4,99	Error `MONTO_INVALIDO`	Regla de negocio ($5 mínimo)	✅ Pasa
CP-11	Sin contrato de adhesión	Usuario con KYC y perfil, sin firmar la adhesión	Error `ADHESION_PENDIENTE`	Fideicomiso (F1-5)	✅ Pasa
CP-12	Sin fondo de emergencia nunca Agresivo	Respuestas muy arriesgadas sin fondo de emergencia	Perfil MODERADO con aviso	Idoneidad del perfil (F1-8)	✅ Pasa
CP-13	Conciliación que cuadra	5 aportes aprobados y cierre del día	Conciliado en los 3 niveles; batch aprobado por el fiduciario; órdenes en renta fija, fondos y acciones	Conciliación (diagrama 4); fideicomiso	✅ Pasa
CP-14	Conciliación con descuadre	Cierre con un descuadre inyectado	No concilia; excepciones `CAPTURADO_SIN_LIQUIDAR` y `DIFERENCIA_LIQUIDACION`	Conciliación (diagrama 4)	✅ Pasa
CP-15	El cierre no se duplica	Ejecutar el cierre dos veces el mismo día	El segundo responde `ya_cerrado`; el fideicomiso no recibe el abono dos veces	Conciliación; integridad contable	✅ Pasa

4.2 Perfil de riesgo con IA (validación del modelo, F1-8)

ID	Caso	Resultado esperado	Requisito que cubre	Resultado
CP-16	El modelo cumple las metas	Exactitud ≥ 85%, F1 ≥ 0,80 en cada clase y 0 Conservadores clasificados como Agresivos (20% de prueba)	Metas de la ficha de IA (Sesión 1)	✅ Pasa
CP-17	El modelo respeta la regla del fondo de emergencia	Sin fondo: nunca Agresivo; con fondo: Agresivo con probabilidad ≥ 60%	Reglas de seguridad	✅ Pasa
CP-18	Baja confianza → revisión humana	Probabilidad < 60%: revisión de un asesor y perfil provisional más conservador	Supervisión humana	✅ Pasa
CP-19	Sin modelo, se usan las reglas	Si el modelo falla, la API sigue funcionando con el puntaje por reglas	Continuidad del servicio	✅ Pasa
CP-20	Dataset reproducible y sintético	Mismo resultado con la misma semilla; sin columnas con datos personales	Uso de datos sintéticos (regla de la cátedra)	✅ Pasa
CP-21	Sin sesgo grueso por edad	Exactitud ≥ 80% en cada grupo de edad	Gestión de sesgos	✅ Pasa

4.3 Casos pendientes para el sandbox real de la pasarela

Estos casos **no se pueden probar con el simulador actual** o no están automatizados todavía; se agregan a la certificación F1-1 cuando la pasarela entregue su sandbox:

ID	Caso	Resultado esperado
CP-P1	Rechazo `05` (no aprobar)	Estado RECHAZADO con mensaje genérico (el simulador ya lo soporta; falta su prueba automatizada)
CP-P2	Liquidación real T+1 de la pasarela	El archivo de liquidación cuadra con los aportes capturados (nivel 2 de conciliación)
CP-P3	Devolución (`/refunds`) de un aporte ya asignado	Se trata como rescate, no como reverso
CP-P4	Autenticación del titular (3-D Secure), si la pasarela la exige	Aporte aprobado solo con autenticación exitosa
CP-P5	Prueba de carga en el sandbox	KPIs comparables a los del prototipo (aprobación, p95, TPS, reversos; ver `docs/KPIS.md`)
CP-P6	Análisis de seguridad del código	SAST (`bandit`) y SCA (`pip-audit`) sin hallazgos altos o críticos

5. Criterios de salida

Fase	Se considera certificada cuando…
Prototipo (Sesión 2)	Los 21 casos automatizados pasan
Fase 1	CP-01 a CP-15 pasan **en el sandbox de la pasarela** y la pasarela emite su aprobación; CP-P1 a CP-P6 resueltos; SAQ A firmado y AOC de la pasarela vigente; autorizaciones F1-3 a F1-7 obtenidas; CP-16 a CP-21 pasan con el modelo en producción

Fase	Se considera certificada cuando…
Fase 2	Homologación con el suiche aprobada; ROC o SAQ D aprobado; escaneos ASV y prueba de penetración sin hallazgos críticos

6. Cronograma estimado (desde la decisión de lanzar)

Mes	Actividad
1	Firma con la pasarela y acceso al sandbox; contrato marco con el banco fiduciario
1–2	Ejecución de CP-01 a CP-15 y CP-P1 a CP-P6 en el sandbox; corrección de hallazgos
2	SAQ A + AOC; expediente ante SUDEBAN y SUNAVAL (fintech, nube, operación vía app)
3	Aprobaciones regulatorias y salida a producción controlada (sandbox regulatorio)
Cuando se cumpla el disparador	Inicio de la fase 2: afiliación directa, homologación con el suiche y PCI-DSS completo

7. Cómo reproducir las pruebas

```
pip install -r requirements.txt
python ia/generar_dataset.py
python ia/entrenar.py
python -m pytest -v
```

8. Supuestos y validaciones pendientes

- El alcance **SAQ A** supone que el PAN se captura en un formulario o iframe alojado por la pasarela. Contrastar con la guía oficial de SAQ de PCI-DSS 4.0 vigente.
- Comisión de la pasarela (3%), códigos de respuesta y tiempos simulados: confirmar con la pasarela elegida.
- Viabilidad del fideicomiso colectivo con adhesión digital: confirmar con el docente y la Ley de Fideicomisos.
- Las resoluciones y circulares de SUDEBAN y SUNAVAL se tomaron del documento de la Sesión 1; verificar su vigencia.